CISSP Domain 6：セキュリティの評価とテスト ― 統合学習ノート

> 2026-10-25。音声で学習・議論した内容を整理。教材の原文が確認できない部分は、解説・補足として記載。

全体像

戦略の策定 → コントロールのテスト → セキュリティプロセスデータの収集 → 監査・アセスメント → 是正・継続的改善。 「管理策が存在する」ことと「有効に機能している」ことは異なる。

6.1 セキュリティ評価・テスト・監査戦略の設計

NIST RMFと関連文書

- **NIST SP 800-37 Rev.2（RMF）**：Prepare → Categorize → Select → Implement → Assess → Authorize → Monitor。リスクに基づく継続的な管理。
- **SP 800-53**：セキュリティ・プライバシー管理策のカタログ。
- **SP 800-53A**：管理策の評価手順・方法。
- **SP 800-171**：非連邦システム等におけるCUI保護の要件。
- **NIST CSF 2.0**：Govern / Identify / Protect / Detect / Respond / Recover。RMFと同じものではない。

ISO・保証報告

- **ISO/IEC 27001**：認証可能なISMS要求事項。**27002**：管理策のガイダンス。**27005**：情報セキュリティリスク管理。
- **27017**：クラウドセキュリティ管理策。**27018**：パブリッククラウドにおけるPII保護。
- ISO 27001 Annex A：2013年版114管理策、2022年版93管理策。番号を混同しない。
- **SOC 1**：財務報告に係る内部統制。**SOC 2**：Trust Services Criteriaに基づく保証。**SOC 3**：一般公開向け概要報告。
- **Type 1**：特定時点の統制の設計（および記述）。**Type 2**：一定期間における運用有効性も対象。
- **COSO**：内部統制の枠組み（17原則）。**SSAE 18**、**ISAE 3402**（サービス組織の統制）と**ISAE 3000**（その他の保証業務）を区別。
- その他の枠組み：PCI DSS、IEC 62443（産業制御）、UK Cyber Essentials、NERC CIP（電力）、UL 2900、CSA STAR、SWIFT CSCF。
- **外部委託してもリスク管理の説明責任は委託元に残る。**

6.2 セキュリティコントロールのテスト

評価の基本

- SP 800-53Aの三手法：**Examine（文書・記録の確認）／Interview（関係者への聴取）／Test（実際の動作検証）**。
- 評価対象、サンプル、証拠、期待結果を明確化。リスクに応じて深さ・頻度を調整。
- **ログ管理**：NIST SP 800-92。取得・集中管理・保全・分析・保存・時刻同期を考慮。
- **Synthetic Monitoring**：疑似取引を定期実行。**RUM**：実利用者の体験を計測。

- **コードレビュー／DevSecOps**：開発中の早期発見。アーキテクチャレビュー・脅威モデリング・SAST・バイナリ解析・手動レビューは目的が異なる。

テストの種類

手法	確認したいこと
Use case	正常な業務・機能の利用
Scenario	具体的な利用・障害・攻撃の状況
Misuse case	悪意ある／想定外の利用
Negative testing	無効な入力や不正な操作を適切に拒否するか
Interface testing	コンポーネント間の境界・連携が正しいか
Compliance testing	規定や手順への準拠
Substantive testing	取引・記録・結果そのものの妥当性

コードカバレッジ：statement、branch、condition、multiple-condition、loop、path、data-flow。カバレッジが高くても欠陥ゼロの保証にはならない。

脆弱性スキャンとペネトレーションテスト

- **脆弱性スキャン**：既知の問題や設定不備を広く検出。**ペンテスト**：許可された範囲で攻撃可能性と影響を実証。
- 事前に**スコープ・実施許可・Rules of Engagement**を確定。ブラインド／ダブルブラインドは情報共有条件の違い。
- **Red Team**：攻撃者の模擬。**Blue Team**：防御・検知・対応。**Purple Team**：協働による改善。
- ペンテストの流れ：**Chartering → Discovery → Scanning → Exploitation → Reporting**（教材での整理）。
- **MITRE ATT&CK**：攻撃者の戦術・技術の知識ベース。**BAS**：攻撃・侵害シミュレーション。**Chaos Engineering**：障害への耐性検証。
- **DMCA §1201**：米国の技術的保護手段回避に関する法的論点。実施許可と適用法令を確認。
- 単発評価と継続評価を区別。NIST RMFやSOC 2 Type 2が常にペンテストを必須とする、と一般化しない。

6.3 セキュリティプロセスデータの収集

アカウント管理

- **Domain 5**はIAMをどう設計・運用するか。**Domain 6**はIAMが有効に機能する証拠をどう集めるか。
- **Identity Store**：誰が登録され、どの属性を持つか。**Entitlements**：何が許可されるか。**ログ／Accounting**：実際に何をしたか。
- 突合によって休眠ID、退職者ID、過剰権限、異常アクセスを検出。**Joiner / Mover / Leaver**と権限棚卸しを重視。
- **UEBA**は振る舞いの異常を示すが、不正の確定証拠とは限らない。

マネジメントレビューと承認

- 経営層がISMSの**適合性・妥当性・有効性**を評価し、改善や資源配分を決定する。

- 主な入力：前回レビューのフォロー、内外の状況変化、パフォーマンス指標、監査結果、不適合・是正、セキュリティ目標、利害関係者のフィードバック、リスク評価・対応状況、改善機会。
- ISO 27001:2022の**9.3.2**がインプット、**9.3.3**がアウトプット。
- **KPI**：統制・目標の達成状況（例：期限内パッチ適用率）。**KRI**：リスクの高まり（例：未修正の重大脆弱性件数）。同じ数値も用途により両者になり得る。
- 良好なKPIが必ずしも低い残留リスクを意味するわけではない。

バックアップ確認データと可用性

- 確認データ：実行日時、成否、対象の網羅率、保存期間、完全性、復元試験の成否、復旧所要時間。
- **バックアップ成功 ≠ 復旧可能**。復元テストと業務再開能力を検証する。
- **RPO**：許容するデータ損失の時間的範囲。**RTO**：復旧までの許容時間。
- ISO 27001:2013 **A.12.3.1** → 2022 **A.8.13**（Information backup）。
- FIPS 200：**CP（Contingency Planning）**は復旧・継続の計画、**MP（Media Protection）**は媒体の保護。

6.4／6.5 監査・アセスメント（読み上げられた後半部分）

> 会話で確認できた「内部監査とアセスメント」「監査の計画と実施」「外部監査とアセスメント」等を、教材で指定された順番に整理。6.4と6.5の正式な節境界は原本未照合。

内部監査とアセスメント

教材で整理した四段階：

1. **実施許可**：目的・対象・権限・責任を明確にする。
2. **テスト**：管理策の設計・実施・運用状況を検証する。
3. **報告**：発見事項、根拠、影響、推奨事項を伝える。
4. **修復**：是正措置を実行し、完了を追跡する。

POA&M（Plan of Action and Milestones）：発見された弱点の改善計画、責任者、期限、進捗を管理。NIST SP 800-37のRMFと関連するが、POA&M自体はRMFの七段階の一つではない。

監査の計画と実施

準備フェーズ：スケジュール・範囲・成功基準を定義 → コントロールの特定 → ギャップ分析 → 優先順位付け・改善 → 解消確認 → 監査・報告アプローチの決定。

監査フェーズ：監査計画の具体化 → 証跡収集 → 作業場所・アクセス準備 → 会議設定 → テスト実施 → 問題解決 → 報告書レビュー → 教訓整理。

外部監査とアセスメント：代表的な六種類

種類	主な目的
コンプライアンス監査	法令・規格・契約・内部規程への準拠
財務監査	財務諸表や財務報告の信頼性
業務監査	業務の効率性・有効性・統制

種類	主な目的
情報システム監査	IT統制・システムの機密性、完全性、可用性
統合監査	複数の監査観点を組み合わせた評価
フォレンジック監査	不正・インシデント等の証拠調査、事実関係の解明

サードパーティ監査とアセスメント

- クラウドサービスプロバイダー（**CSP**）、インターネットサービスプロバイダー（**ISP**）、マネージドセキュリティサービスプロバイダー（**MSSP**）、コンサルタント・アドバイザーなどが対象。
- サプライチェーンや外部委託のリスクを、契約・アクセス権・サービス水準・監査報告・インシデント対応能力などから評価。
- **委託しても組織のリスク管理責任は消えない。**

マネージドサービスとセキュリティアセスメント

セキュリティ専門家が関与する二つのケース：

1. **セキュリティに直結するサービス**：IAM、インシデント対応、事業継続（BC）、災害復旧（DR）などを提供する事業者。
2. **別分野のサービスでも組織資産にアクセスする事業者**：施設・人材・情報・情報システムを共有または利用する委託先。

重要なのは、事業者の業種名ではなく**実際のアクセス範囲とリスク**。

ロケーション

- 証拠収集は**対面**でも**電子的**にも実施可能。
- 対象は**組織所有・管理の資産（オンプレミス）／クラウド資産／両者の組合せ**。
- 現地確認、設定エクスポート、ログ、監査報告書、リモートインタビューなどを組み合わせる。
- **クラウド＝必ずリモート監査**ではない。所在にかかわらず、十分で信頼できる証拠が必要。

試験直前チェック

比較	覚えるべき違い
800-53 / 800-53A / 800-37	管理策カタログ / 評価方法 / RMF
NIST CSF / RMF	成果・機能の枠組み / リスク管理プロセス
SOC 1 / SOC 2 / SOC 3	財務報告統制 / Trust Services / 一般公開向け
Type 1 / Type 2	時点の設計 / 期間の運用有効性
Examine / Interview / Test	記録を見る / 人に聞く / 動作を試す
脆弱性スキャン / ペンテスト	問題を発見 / 悪用可能性を検証
KPI / KRI	目標・統制の成果 / リスク兆候
RPO / RTO	許容データ損失 / 許容復旧時間

比較	覚えるべき違い
CP / MP	緊急時の継続・復旧 / 媒体保護
内部監査 / 外部監査	組織内部による評価 / 組織外の主体による評価
管理策の導入 / 有効性の証明	実装した事実 / 運用証拠・テスト結果

CISSPの判断軸：ツール導入の有無だけでなく、事業リスクに照らした評価範囲、証拠の信頼性、是正措置、経営層への報告・意思決定を重視する。